

SIMATS ENGINEERING

ASSESSMENT TOOL 2

Name	SHAIK REEHAN
Register Number	192565071
Date	
Time	1hr

COURSE NAME: Cybersecurity Incident Handling and Response
COURSE CODE: CSA60

COURSE OUTCOME COVERED

CO4: Appraise containment, eradication, recovery strategies by selecting appropriate techniques such as isolation, malware removal, patch management, system restoration to ensure secure operations. (BL3, BL4)

Activity Tool : Malware Eradication and System Hardening (Medium)
Assessment Tool Weightage: 20%

Code of Conduct:

I _____shaikreehan192565071_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

SHAIK REEHAN

RUBRICS FOR CALCULATION:

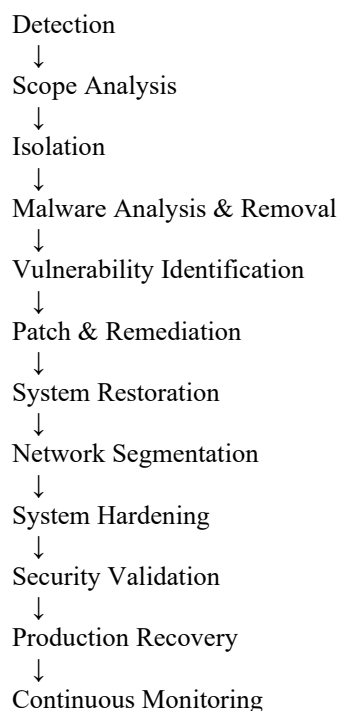
Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Malware Detection and Eradication	25%	Thoroughly identifies malware, malicious processes, files, and persistence mechanisms and completely removes the threat with proper verification.	Identifies and removes most malware components with minor omissions.	Performs basic malware removal but misses some malicious components or persistence mechanisms.	Unable to identify or remove the malware effectively.
Vulnerability Remediation and Patch Management	20%	Accurately identifies exploited vulnerabilities, applies appropriate patches or fixes, and verifies that vulnerabilities are fully remediated.	Identifies and remediates major vulnerabilities with minor gaps in verification.	Performs basic patching or remediation but misses important vulnerabilities.	Unable to identify or remediate relevant vulnerabilities.
System and Network Hardening	25%	Effectively applies comprehensive hardening techniques including secure configurations, least privilege, firewall controls, service reduction, authentication, and network security.	Applies appropriate hardening techniques with minor configuration gaps.	Implements basic hardening but leaves significant security weaknesses.	Unable to apply appropriate system or network hardening measures.
Recovery and Security Validation	15%	Successfully restores affected systems, validates system integrity, verifies malware removal, and performs thorough post-recovery security checks.	Restores and validates systems with minor omissions.	Performs basic recovery and validation but misses important security checks.	Unable to safely restore or validate the recovered systems.
Documentation and Incident Report	15%	Provides clear, professional documentation covering malware analysis, eradication, vulnerabilities, hardening actions, validation results, evidence, and conclusions.	Documentation is well organized with most required evidence and findings.	Documentation is partially organized with limited evidence or analysis.	Documentation is incomplete, poorly organized, and lacks supporting evidence.

1. Comprehensive Malware Eradication and System Hardening

Introduction

When a company experiences a malware attack that compromises multiple endpoints and exploits an unpatched vulnerability, the response must go beyond simply deleting the malware. A complete process should **contain the infection, identify and eradicate all malicious components, remediate the exploited vulnerability, restore systems safely, harden the environment, validate security, and continuously monitor the network.**

The overall process is:



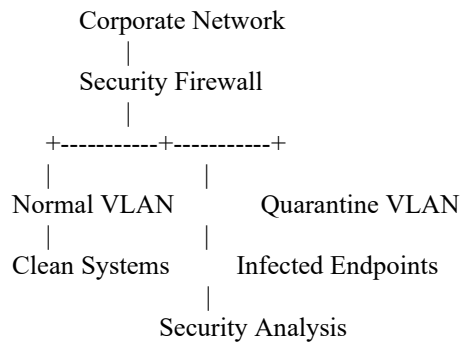
1. Isolation and Containment

The first priority is to prevent the malware from spreading further.

The security team should:

1. Identify all suspected and confirmed infected endpoints.
2. Isolate infected systems from the network using EDR/NAC controls.
3. Disconnect severely compromised systems when necessary.
4. Place suspicious systems into a quarantine VLAN.
5. Block known malicious IP addresses, domains, ports, and protocols.
6. Disable compromised user or administrator accounts.
7. Restrict communication between affected endpoints and critical servers.
8. Preserve logs and forensic evidence before making destructive changes where appropriate.

A quarantine architecture can be represented as:



Isolation prevents infected endpoints from performing lateral movement while allowing security personnel to investigate them.

2. Malware Detection and Eradication

A. Identify Malicious Components

The security team should determine exactly what the malware changed.

Investigation should include:

- Malicious executables and scripts
- Suspicious processes
- Startup entries
- Scheduled tasks
- Services
- Registry modifications
- Unauthorized user accounts
- Persistence mechanisms
- Suspicious network connections
- Malicious domains and IP addresses
- Modified system files
- Indicators of compromise (IOCs)

EDR, antivirus, SIEM, IDS/IPS, and forensic tools can be used to correlate evidence across endpoints.

B. Remove the Malware

After collecting required evidence, malware should be removed using approved security procedures.

Actions may include:

- Terminating malicious processes.

- Removing malicious files.
- Removing persistence mechanisms.
- Removing unauthorized accounts.
- Removing malicious scheduled tasks and services.
- Clearing malicious startup entries.
- Resetting compromised credentials.
- Reimaging severely compromised endpoints when trust in the operating system cannot be established.

For highly compromised systems, **secure reimaging from a known-good source is safer than attempting to manually clean every component.**

C. Verify Eradication

Malware removal must be verified rather than assumed.

Verification should include:

- Full endpoint security scans.
- Offline or secondary malware scans where appropriate.
- IOC searches.
- Process inspection.
- Startup/persistence checks.
- Network-connection analysis.
- Log review.
- Repeat vulnerability scans.

The system should only move to recovery when there is reasonable evidence that the malware and its persistence mechanisms have been eliminated.

3. Vulnerability Remediation and Patch Management

The malware exploited an unpatched vulnerability, so removing the malware alone would leave the organization vulnerable to reinfection.

Step 1: Identify the Exploited Vulnerability

The security team should determine:

- Vulnerability identifier/CVE where applicable.
- Affected software and versions.
- Systems running the vulnerable software.
- Whether exploitation occurred.
- Whether public exploits exist.
- Whether other systems have the same vulnerability.

Step 2: Prioritize Vulnerabilities

Risk should be assessed using:

- Severity.
- Exploit availability.
- Active exploitation.
- Internet exposure.
- Asset criticality.
- Business impact.
- Presence of compensating controls.

A critical actively exploited vulnerability should receive the highest priority.

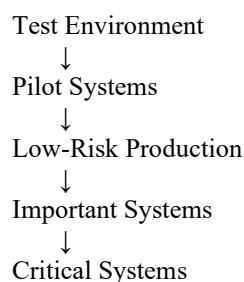
Step 3: Test the Patch

Before large-scale deployment:

1. Apply the patch in a test environment.
2. Test critical applications.
3. Check system compatibility.
4. Check performance.
5. Verify security tools continue functioning.
6. Document any issues.

Step 4: Deploy the Patch

Deployment should occur in stages:



Backups and recovery procedures should be available before patching critical systems.

Step 5: Verify Remediation

After patch deployment:

- Verify the installed patch/version.
- Perform vulnerability scanning.
- Check security logs.
- Confirm the vulnerable service is protected.
- Confirm the original vulnerability is no longer detected.
- Monitor for attempted exploitation.

4. System Restoration

Once malware eradication and vulnerability remediation are complete, affected systems can be restored.

The restoration process should include:

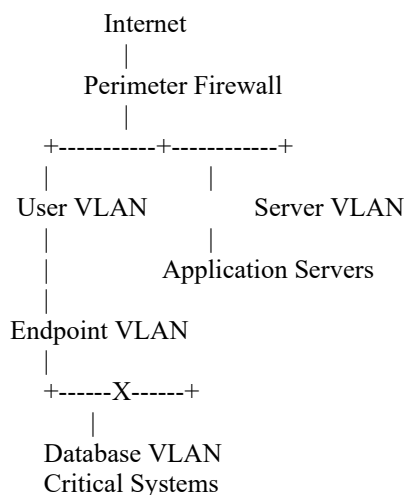
1. Select a known-good backup or clean system image.
2. Confirm backup integrity.
3. Restore the operating system and required applications.
4. Apply current security patches.
5. Restore only required business data.
6. Scan restored systems.
7. Verify system integrity.
8. Test applications and services.
9. Confirm security configurations.
10. Obtain authorization before production reconnection.

Critical systems should not be restored from backups that were created after the malware infection unless those backups have been thoroughly validated.

5. Network Segmentation

Network segmentation should be strengthened to reduce the impact of future infections.

A secure architecture may contain:



Security controls should ensure:

- Users cannot directly access critical databases unless required.

- Servers communicate only through required ports.
- Administrative systems are separated from normal user systems.
- Infected devices can be automatically moved to a quarantine VLAN.
- Firewall rules restrict unnecessary east-west traffic.
- Management interfaces are accessible only to authorized administrators.

This limits lateral movement if another endpoint becomes infected.

6. System Hardening

After restoration, systems should be hardened to reduce the attack surface.

Operating System Hardening

- Apply current security updates.
- Disable unnecessary services.
- Remove unnecessary applications.
- Close unused ports.
- Enable host-based firewalls.
- Enable endpoint protection.
- Configure secure logging.
- Disable insecure legacy protocols where possible.

Account and Authentication Security

- Apply least privilege.
- Remove unnecessary administrator accounts.
- Use strong authentication.
- Enable MFA for privileged and remote access.
- Review service accounts.
- Rotate credentials that may have been exposed.
- Apply appropriate password and account policies.

Application Hardening

- Remove unnecessary application components.
- Use secure configurations.
- Restrict application permissions.
- Keep applications updated.
- Enable application logging.
- Use allowlisting where appropriate.

Network Hardening

- Apply firewall rules.
- Restrict unnecessary inbound and outbound traffic.

- Implement VLAN segmentation.
 - Restrict administrative protocols.
 - Monitor internal traffic.
 - Use IDS/IPS and EDR controls.
-

7. Security Validation

Before returning systems to normal operations, comprehensive validation must be performed.

Validation should include:

Malware Validation

- Full malware scan.
- IOC search.
- Persistence check.
- Process inspection.
- Network connection analysis.

Vulnerability Validation

- Vulnerability scan.
- Patch verification.
- Configuration assessment.
- Confirmation that the exploited vulnerability is remediated.

Integrity Validation

- Verify system files.
- Compare configurations against approved baselines.
- Check security logs.
- Confirm no unauthorized accounts or services exist.

Functional Validation

- Test business applications.
- Test required network connections.
- Verify authentication.
- Verify database/application communication.
- Confirm backup and recovery functionality.

Only systems that pass security and functional testing should be returned to production.

8. Continuous Monitoring

After recovery, increased monitoring should be maintained.

Security teams should monitor:

- EDR alerts.
- SIEM events.
- Firewall logs.
- Authentication activity.
- Network traffic.
- DNS requests.
- Endpoint behavior.
- Vulnerability status.
- Patch compliance.
- Suspicious processes.
- Repeated malware indicators.

For a defined period after the incident, monitoring should be more intensive than normal to detect reinfection or attacker persistence.

9. Documentation and Incident Report

A professional incident report should contain:

Incident Information

- Date and time of detection.
- Incident classification.
- Affected systems.
- Initial attack vector.
- Malware identified.

Investigation

- Indicators of compromise.
- Malicious processes/files.
- Persistence mechanisms.
- Vulnerability exploited.
- Evidence collected.
- Systems affected.

Containment

- Systems isolated.

- VLAN changes.
- Firewall rules.
- Blocked IPs/domains.
- Disabled accounts.

Eradication

- Malware removed.
- Persistence removed.
- Systems reimaged where necessary.
- Credentials reset.

Remediation

- Vulnerability patched.
- Security configurations changed.
- Network segmentation improved.

Validation and Recovery

- Malware scans completed.
- Vulnerability scans completed.
- Backups validated.
- Applications tested.
- Production approval obtained.

Lessons Learned

The organization should identify why the vulnerability remained unpatched and improve:

- Patch management.
 - Asset inventory.
 - Vulnerability management.
 - Network segmentation.
 - Endpoint protection.
 - Security monitoring.
 - Incident-response procedures.
-

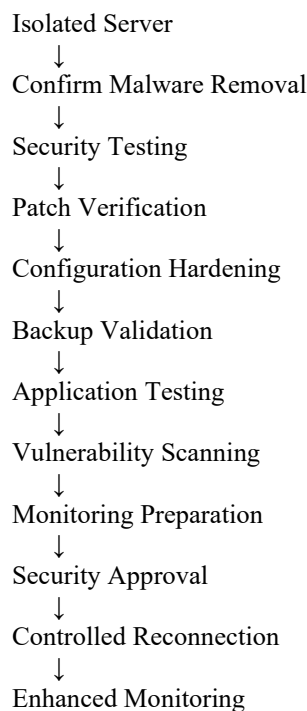
2. Malware Eradication and Secure Return to Normal Operations

Scenario

A healthcare organization discovers malware on a critical application server. The server has already been isolated and the malware has been removed.

Because the server supports a healthcare environment, reconnecting it to production should occur only after **security validation, functional validation, backup verification, hardening, monitoring preparation, and formal approval.**

The process should be:



1. Confirm Malware Eradication

Although the malware has reportedly been removed, the security team must independently verify this.

Perform:

- Full malware/EDR scan.
- IOC search.
- Process inspection.
- Service inspection.
- Scheduled-task inspection.
- Startup/persistence inspection.

- Review of authentication logs.
- Review of network connections.
- Search for unauthorized accounts.
- Review of recent system changes.

If evidence of persistence remains, the server should remain isolated.

If the server cannot be trusted, it should be rebuilt from a known-good image rather than returned to production.

2. Security Testing

The server should undergo security testing before reconnection.

Testing should include:

Malware Testing

- Full antivirus/EDR scan.
- IOC comparison.
- Persistence checks.
- Suspicious process detection.

Vulnerability Testing

- Run an authenticated vulnerability scan.
- Identify missing patches.
- Check vulnerable services.
- Verify that the original exploited vulnerability has been fixed.

Configuration Testing

Compare the server against the organization's approved secure configuration baseline.

Check:

- Open ports.
 - Running services.
 - User accounts.
 - Firewall settings.
 - Authentication settings.
 - Logging configuration.
 - Security software status.
-

3. Patch Verification

The exploited vulnerability must be completely remediated.

The analyst should:

1. Identify the vulnerable software/version.
2. Confirm the appropriate security patch.
3. Verify the patch was successfully installed.
4. Reboot if required.
5. Confirm the expected software version.
6. Run another vulnerability scan.
7. Confirm the vulnerability is no longer detected.

The server should **not** be reconnected simply because the malware has disappeared. The vulnerability that allowed the attack must also be addressed.

4. Configuration Hardening

The server should be hardened before returning to production.

Services

- Disable unnecessary services.
- Remove unnecessary software.
- Close unused ports.
- Restrict administrative interfaces.

Accounts

- Remove unauthorized accounts.
- Apply least privilege.
- Review service accounts.
- Reset potentially compromised credentials.
- Enable MFA for supported administrative access.

Firewall

Only required communication should be allowed.

For example:

ALLOW Application Users → Application Server : Required Service
ALLOW Application Server → Database : Required Database Port
ALLOW Monitoring System → Application Server : Monitoring Traffic
DENY Unnecessary External Access

DENY Unnecessary Internal Access

Logging

Ensure that:

- Security logs are enabled.
- Application logs are enabled.
- Logs are forwarded to the SIEM.
- Important security events generate alerts.
- System time is synchronized.

5. Backup Validation

Before reconnecting the server, verify that reliable recovery data exists.

The team should:

- Confirm the latest backup.
- Check backup integrity.
- Verify backup date and completeness.
- Ensure backups are not contaminated.
- Confirm restoration procedures.
- Perform a test restoration when practical.

For a critical healthcare application, recovery procedures should be documented and tested so that the organization can quickly recover if reinfection occurs.

6. Application and Functional Testing

Security validation alone is insufficient because the server supports a critical application.

Test:

- Application startup.
- User authentication.
- Database connectivity.
- Required APIs/services.
- Application transactions.
- Logging.
- Network communication.
- Performance.
- Availability.

Testing should be performed in an isolated or controlled environment whenever possible before production reconnection.

7. Final Vulnerability and Integrity Scan

A final security assessment should confirm:

Malware Scan → Clean
IOC Search → No Match
Persistence Check → Clean
Patch Verification → Complete
Vulnerability Scan → No Critical Findings
Configuration → Hardened
Firewall → Correct
Backup → Valid
Application Test → Passed
Logging → Working

Any unresolved critical security issue should prevent production reconnection unless formally accepted through the organization's risk-management process.

8. Monitoring Preparation

Before reconnecting the server, enhanced monitoring should be enabled.

The security team should configure:

- EDR monitoring.
- SIEM log collection.
- Firewall monitoring.
- IDS/IPS alerts.
- Authentication monitoring.
- File-integrity monitoring where appropriate.
- Application monitoring.

Special attention should be given to the indicators associated with the original malware.

9. Approval Before Reconnection

A critical healthcare server should not be reconnected by a single analyst without authorization.

A formal approval process should involve appropriate stakeholders such as:

- Cybersecurity team.
- System/application owner.
- IT operations.
- Incident-response lead.
- Relevant healthcare/security compliance personnel.

The approval should confirm that:

- Malware has been eradicated.
 - The exploited vulnerability has been remediated.
 - Security testing has passed.
 - Configuration has been hardened.
 - Backups are valid.
 - Application functionality has been verified.
 - Monitoring is active.
 - Residual risks are documented and accepted where applicable.
-

10. Controlled Reconnection

The server should be reconnected using a controlled approach.

Instead of immediately returning it to unrestricted production:

1. Connect it to the appropriate segmented network.
2. Apply restrictive firewall rules.
3. Monitor traffic closely.
4. Validate application functionality.
5. Gradually restore required communication.
6. Watch for suspicious behavior.

If malicious activity appears again, immediately isolate the server and restart the investigation.

11. Post-Recovery Monitoring

After reconnection, the server should receive enhanced monitoring.

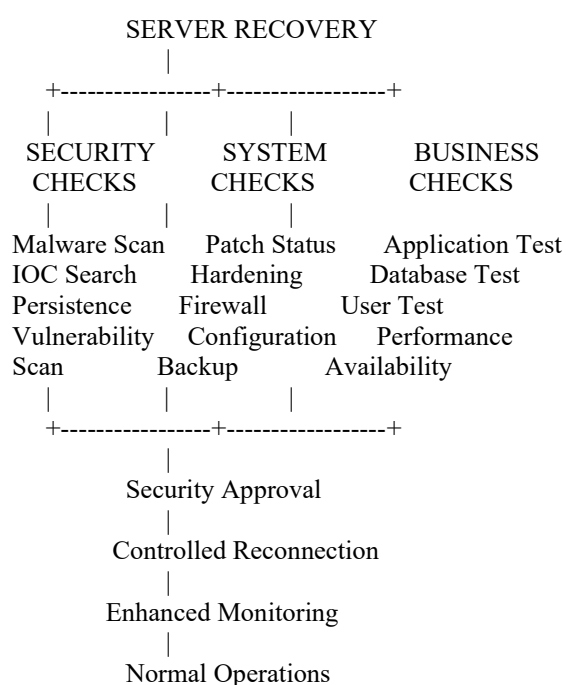
Security analysts should look for:

- Repeated malware detections.
- Suspicious processes.
- Unexpected outbound connections.
- Authentication anomalies.
- Unauthorized configuration changes.

- Unusual application behavior.
- Repeated exploitation attempts.
- Unexpected traffic to other internal systems.

Monitoring should continue until the incident-response team determines that the environment has returned to a stable state.

Final Secure-Recovery Checklist



Conclusion

A successful malware response does not end when the malicious file is deleted. The organization must ensure that the **malware, persistence mechanisms, exploited vulnerability, and security weaknesses** have all been addressed.